Identificar a diferença entre a atividade normal e um incidente

nformações gerais da atividade

O Event Threat Detection é um dos serviços do Security Command Center (SCC). É uma análise de ameaças baseada em registros que monitora continuamente os registros do Google Cloud em busca de possíveis ameaças. Quando identifica alguma atividade suspeita, ele gera uma descoberta para você investigar.

Neste laboratório, você vai analisar descobertas no Google Cloud Security Command Center e conferir os eventos relacionados no Cloud Logging.

Cenário

Recentemente a equipe de segurança detectou duas descobertas de ameaças, relacionadas a atividades suspeitas em contas de usuário. As descobertas foram prontamente investigadas e corrigidas. A equipe concluiu que uma das descobertas era uma atividade comum de usuário, enquanto a outra era de fato maliciosa. Chloe, a líder da sua equipe, encarregou você de analisar os detalhes das descobertas para entender a diferença entre atividade normal e atividade maliciosa. Para isso, você vai recriar a atividade maliciosa para acionar os detectores do IAM, analisar os registros das descobertas de ameaças e corrigir o problema.

Confira como fazer a tarefa: **primeiro** você vai dar permissões a uma conta externa para acionar uma descoberta do IAM pelo Event Threat Detection. **Depois** vai usar o Security Command Center para acessar as duas descobertas do IAM. **Em seguida**, vai utilizar o Security Command Center e o Cloud Logging para conferir os detalhes das descobertas e identificar qual é a atividade comum e qual é a anomalia. **Por último**, você vai ajustar as configurações do IAM para corrigir a descoberta relacionada à atividade maliciosa.

Configuração

Tarefa 1: Dar permissões a uma conta externa

Nesta tarefa, você vai dar direitos de proprietário do projeto a uma conta externa do Gmail. Dar direitos de proprietário a uma conta externa vai acionar os detectores do IAM do Event Threat Detection. Dar esses direitos a uma conta externa é considerado um comportamento anômalo ou possivelmente malicioso. O Event Threat Detection vai identificar essa atividade como uma ameaça e gerar descobertas, que você vai analisar nas próximas tarefas.

1. No console do Google Cloud, no **menu de navegação** (☰), clique em **IAM e administrador** > **IAM**. A página **IAM** será aberta.

Na guia **Visualizar por principais**, confira os dois usuários estudantes que foram configurados automaticamente na organização qwiklabs.net. São os mesmos usuários que aparecem no painel **Detalhes do laboratório** como **Nome de usuário 1 do Google Cloud** e **Nome de usuário 2 do Google Cloud**.

No processo normal de provisionamento, uma conta de serviço concedeu aos dois usuários automaticamente os papéis de proprietário no projeto do laboratório. Isso vai acionar um alerta de descoberta ou de incidente porque um principal externo tem o papel de proprietário. Mas, dado que os usuários fazem parte da organização qwiklabs.net, o alerta é considerado uma atividade normal. Você vai analisar a descoberta depois.

2. Na guia **Visualizar por principais**, clique em **Permitir acesso**. A caixa de diálogo **Permitir acesso** será aberta.
3. Na seção **Adicionar principais**, no campo **Novos principais**, digite **bad.actor.demo@gmail.com**.
4. Expanda o menu suspenso **Selecionar papel** e selecione **Básico** e depois **Proprietário**.
5. Clique em **Salvar**.

Você atribuiu o papel de proprietário ao usuário externo bad.actor.demo@gmail.com. Isso vai acionar uma descoberta no SCC porque o usuário está fora da organização qwiklabs.net.

Clique em **Verificar meu progresso** para confirmar que você concluiu a tarefa corretamente.

Dar permissões a uma conta externa

Tarefa 2: Acessar as descobertas do Event Threat Detection

Nesta tarefa, você vai acessar as descobertas do Event Threat Detection no Security Command Center.

1. No console do Google Cloud, no **menu de navegação** (☰), clique em **Segurança > Descobertas**. A página **Descobertas** será aberta.

O painel **Resultados da consulta de descobertas** vai mostrar três descobertas com alta gravidade. Neste laboratório, você vai analisar duas descobertas do tipo **Persistência: concessão anômala do IAM** para determinar se são atividades normais ou maliciosas.

Observação: *se as descobertas* ***Persistência: concessão anômala do IAM*** *não aparecerem, aguarde alguns minutos e atualize a página. Continue a atividade quando as duas descobertas ativas aparecerem.*

A descoberta **Persistência: concessão anômala do IAM** indica que uma concessão anômala do IAM foi detectada. Isso significa que um usuário ou uma conta de serviço recebeu acesso a um recurso que eles não deveriam acessar. É um possível sinal de que um usuário malicioso está tentando acessar o ambiente sem autorização.

Em seguida, filtre as descobertas para mostrar uma lista da categoria **Persistência: concessão anômala do IAM**.

2. No painel **Filtros rápidos**, na seção **Categoria**, marque a caixa de seleção da categoria **Persistência: concessão anômala do IAM**.

Observação: *quando você seleciona atributos com os filtros rápidos, eles são adicionados automaticamente à consulta. A prévia da consulta será atualizada com a categoria selecionada,* ***Persistência: concessão anômala do IAM****. Se quiser encontrar determinadas descobertas ou grupos de descobertas, edite a consulta.*

O filtro retornou duas descobertas do tipo **Persistência: concessão anômala do IAM**.

3. Clique no cabeçalho da coluna **Horário do evento** para colocar as descobertas em ordem decrescente, com as mais recentes acima.

Tarefa 3: Analisar as descobertas

Nesta tarefa, você vai analisar as descobertas e determinar qual representa uma atividade normal e qual é um incidente verdadeiro.

1. No painel **Resultados da consulta de descobertas**, na coluna **Categoria**, clique na descoberta **Persistência: concessão anômala do IAM** com o horário mais antigo. A caixa de diálogo **Persistência: concessão anômala do IAM** será aberta com a guia **Resumo**, que mostra um resumo da descoberta.

2. Ache a linha **E-mail da conta principal**. Essa é a conta de serviço que deu o papel de proprietário ao usuário. Ela faz parte da organização qwiklabs.net. Com essas informações, é possível concluir que essa descoberta representa uma atividade normal e esperada.

3. Clique na guia **Propriedades de origem** e expanda **Propriedades > sensitiveRoleGrant > Membros**. O endereço de e-mail em **principalEmail** é o usuário que concedeu o papel de proprietário, enquanto o endereço em **Membros** é o usuário que o recebeu.

Which user was granted the owner role in the earliest Persistence: IAM Anomalous Grant finding record?

The external user bad.actor.demo@gmail.com

A user belonging to the qwiklabs.net organization

None of these options

A Compute Engine service account

A seguir, você vai achar a atividade maliciosa relacionada à conta externa de usuário que você autorizou, bad.actor.demo@gmail.com.

4. Clique no botão Fechar (**X**) para voltar à página **Descobertas**.
5. No painel **Resultados da consulta de descobertas**, na coluna **Categoria**, clique na descoberta **Persistência: concessão anômala do IAM** com o horário mais recente.
6. Confira o valor da linha **E-mail da conta principal**. Esse é o endereço de e-mail da conta que deu o papel de proprietário ao usuário.
7. Clique na guia **Propriedades de origem** e expanda **Propriedades > sensitiveRoleGrant > Membros**. A conta indicada é bad.actor.demo@gmail.com, uma conta de usuário externa. Com essas informações, é possível concluir que essa descoberta está associada a um usuário malicioso sem autorização.

Which user was granted the owner role in the Persistence: IAM Anomalous Grant finding with the latest event time?

A student user belonging to the qwiklabs.net organization

The external bad.actor.demo@gmail.com user

The default Compute Engine service account

None of these options

Which Persistence: IAM Anomalous Grant finding is a genuine incident?

Both findings are genuine incidents

The finding with the earlier event time

The finding with the latest event time

None of these options

Tarefa 4: Acessar as descobertas no Cloud Logging

Nesta tarefa, você vai acessar no Cloud Logging os eventos relacionados às descobertas do Security Command Center.

1. Na barra de título do console do Google Cloud, digite **Análise de registros** no campo **Pesquisar** e clique em **Análise de registros** nos resultados da pesquisa. A página **Análise de registros** será aberta.
2. Clique em **Fixar** ao lado de **Geração de registros de observabilidade**.
3. Copie esta consulta no editor de **Consultas**, na parte de cima da página:

protoPayload.authorizationInfo.permission="resourcemanager.projects.setIamPolicy"

protoPayload.methodName="InsertProjectOwnershipInvite"

Copiado.

A consulta vai filtrar os registros do IAM.

3. Clique em **Executar consulta**. Os resultados da consulta serão exibidos no painel **Resultados da consulta**.
4. No painel **Resultados da consulta**, expanda o registro de auditoria do seu projeto.
5. Clique em **Expandir campos aninhados**. Todos os campos aninhados do registro vão ficar visíveis.

Agora é possível analisar os detalhes do evento da solicitação anômala, incluindo informações como:

- **authenticationInfo**: o e-mail do usuário que fez a solicitação.
- **request**: a identidade de e-mail do usuário que recebeu a concessão anômala.
- **request Metadata**: o endereço IP do sistema em que a solicitação foi feita e o user agent do navegador da Web usado.

Essas informações podem ser essenciais ao investigar se um evento é uma atividade normal ou uma ameaça real.

Which user account made the request to grant the project owner role to the bad.actor@gmail.com user?

A student user belonging to the qwiklabs.net organization

None of these options

An external @gmail.com account

A Google Cloud IAM service account

Tarefa 5: Corrigir a descoberta

Nesta tarefa, você vai remover o papel de proprietário do projeto concedido ao usuário externo, o que vai corrigir a descoberta maliciosa do tipo **Persistência: concessão anômala do IAM**.

1. No console do Google Cloud, no **menu de navegação** (☰), clique em **IAM e administrador** > **IAM**. A página **IAM** será aberta.
2. Ao lado do usuário **bad.actor.demo@gmail.com**, clique no ícone **Editar principal** (✎). A página **Editar permissões** será aberta.
3. Clique no ícone **Excluir** (🗑) para excluir o papel de proprietário.
4. Clique em **Salvar**.

A política será atualizada, e o papel de proprietário será removido do usuário bad.actor.demo@gmail.com.

Clique em **Verificar meu progresso** para confirmar que você concluiu a tarefa corretamente.

Corrigir a descoberta

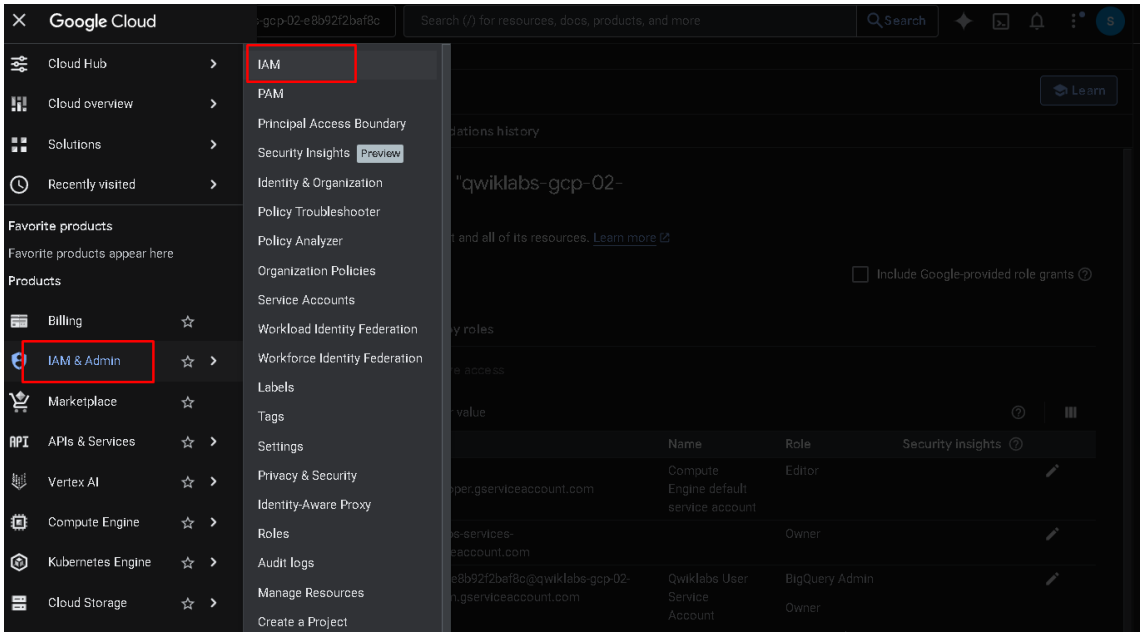
Conclusão

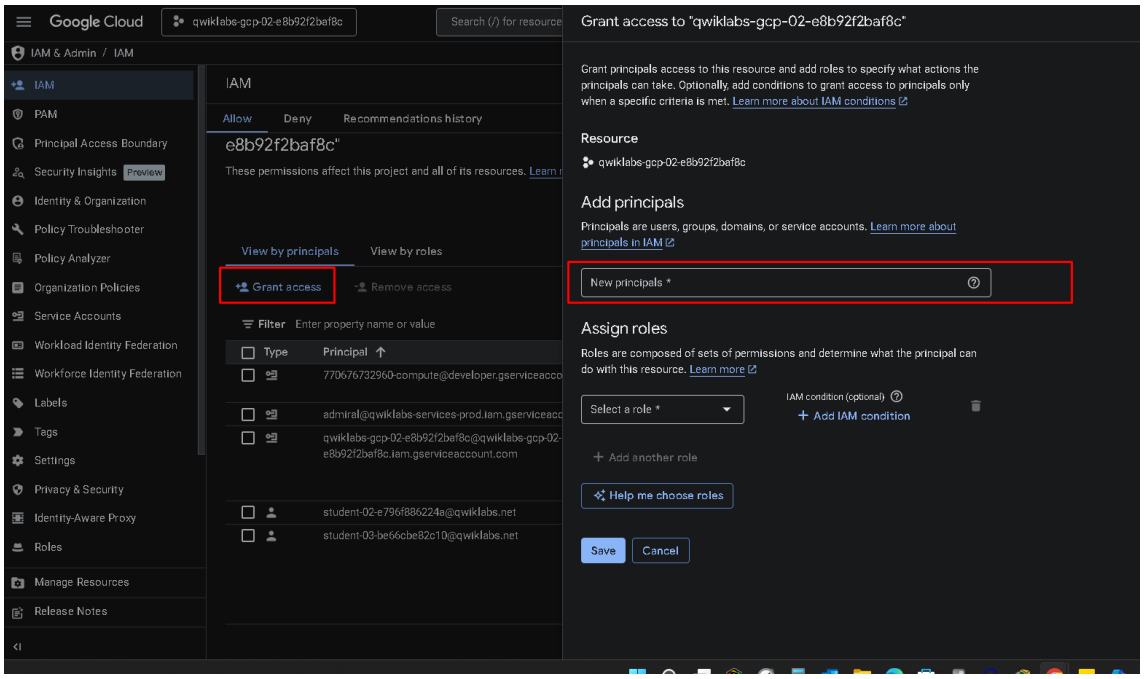
Bom trabalho! Neste laboratório, você aprendeu na prática a analisar um alerta de segurança para saber se é uma atividade maliciosa real.

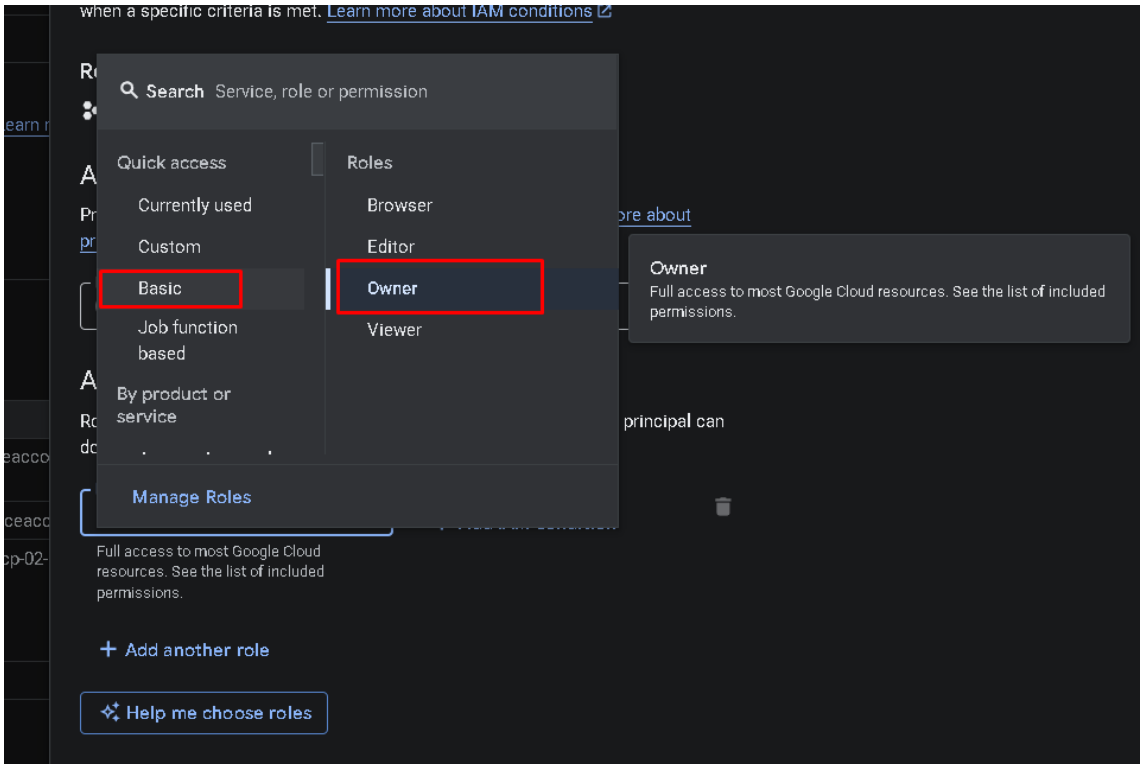
Para isso, você deu permissões a um usuário externo, conferiu as descobertas do Event Threat Detection no Security Command Center e acessou as descobertas no Cloud Logging. Por último, você retirou do usuário externo o papel de proprietário do projeto, o que corrigiu a descoberta.

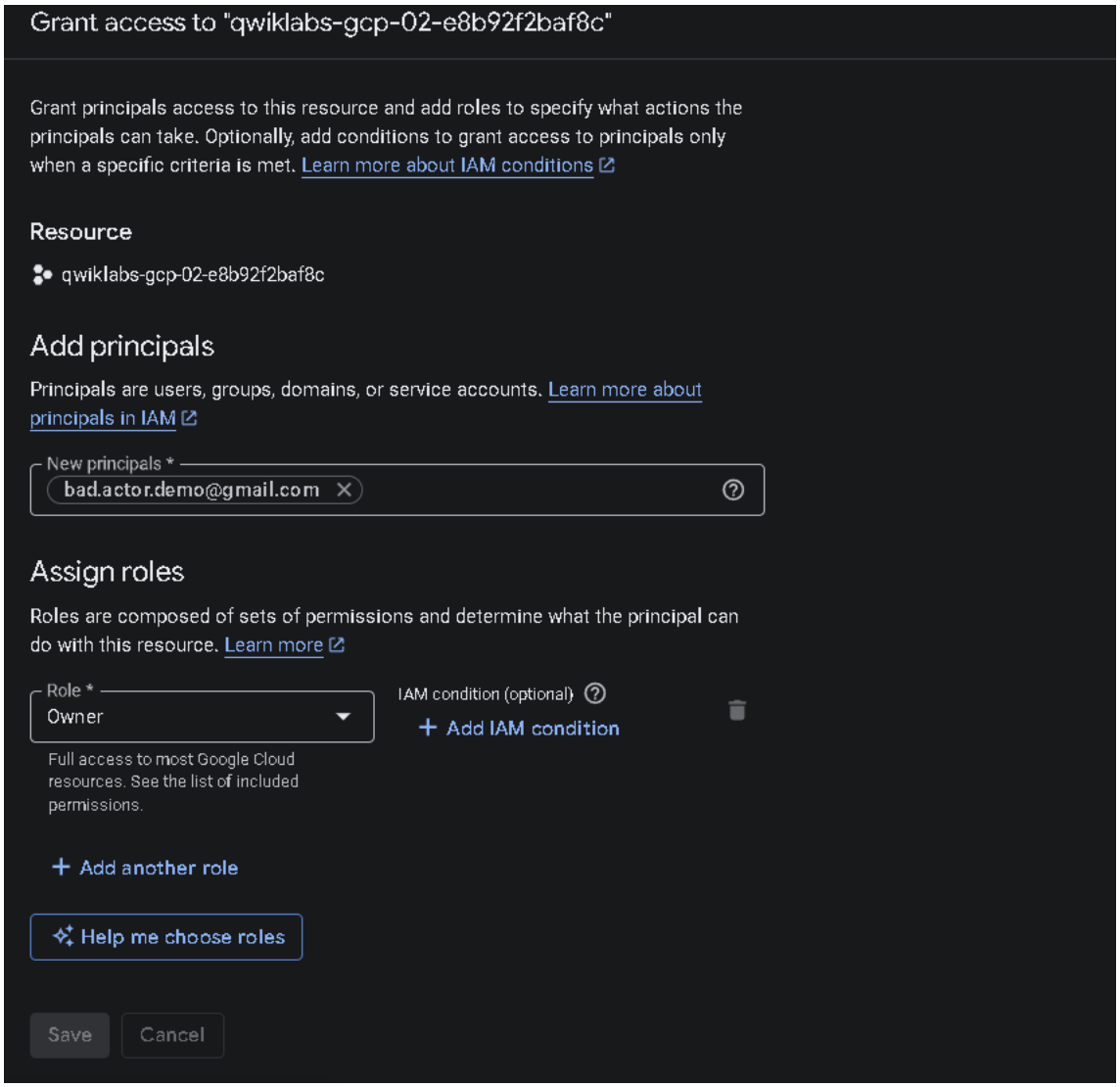
Como analista de segurança, use essas habilidades para conter, mitigar e corrigir ameaças rapidamente.

Tarefa 1: Dar permissões a uma conta externa

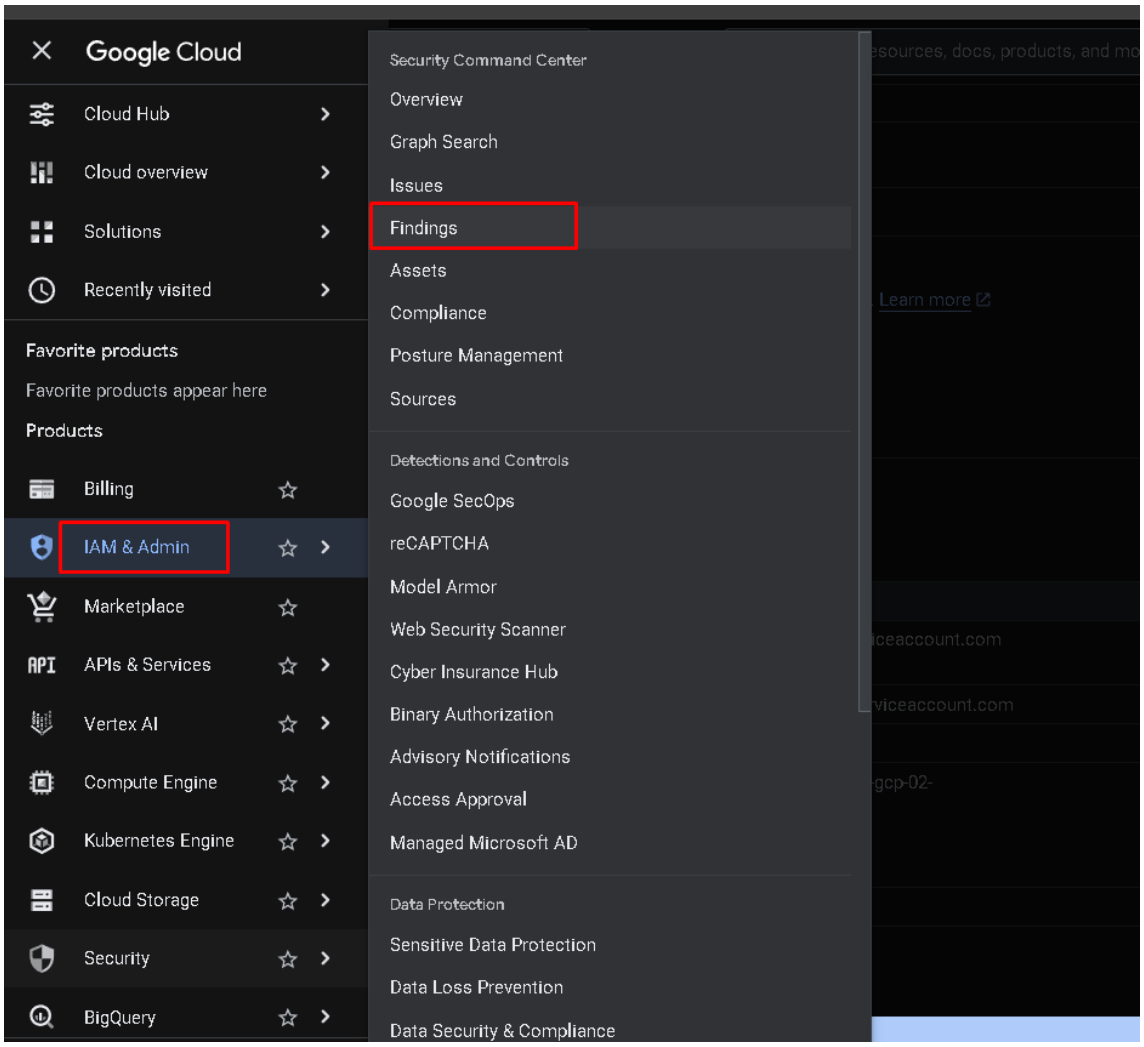


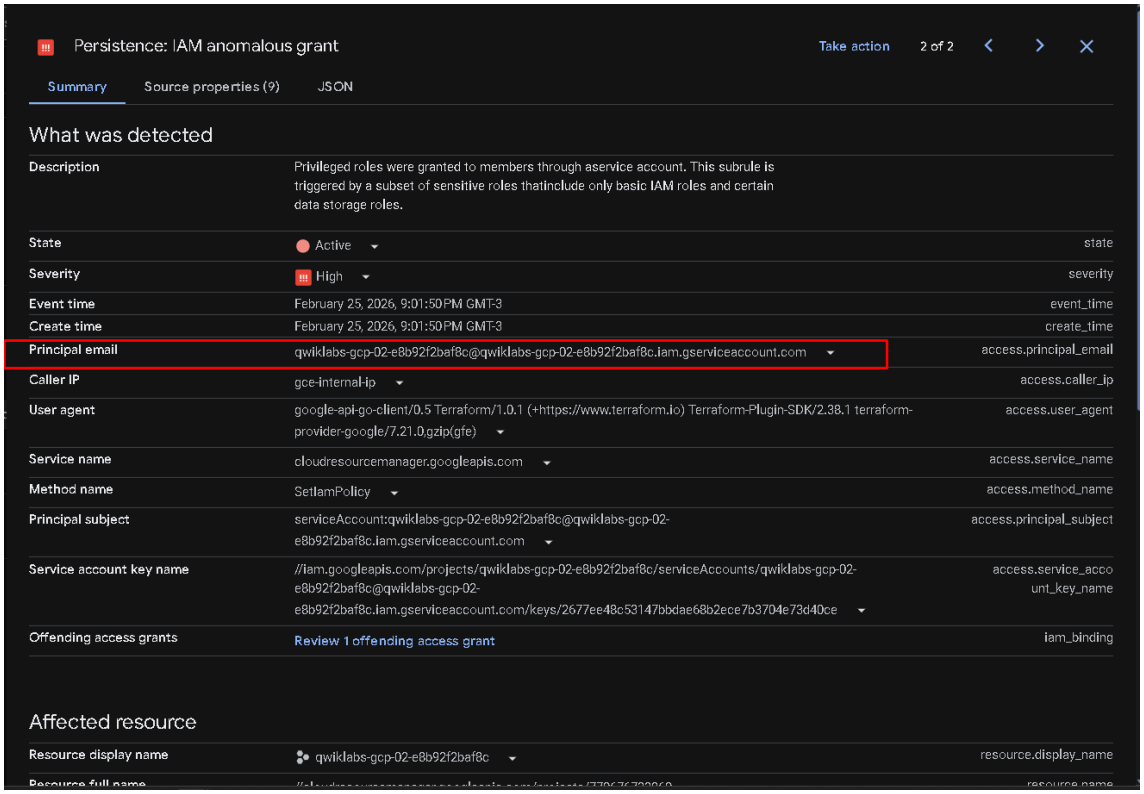


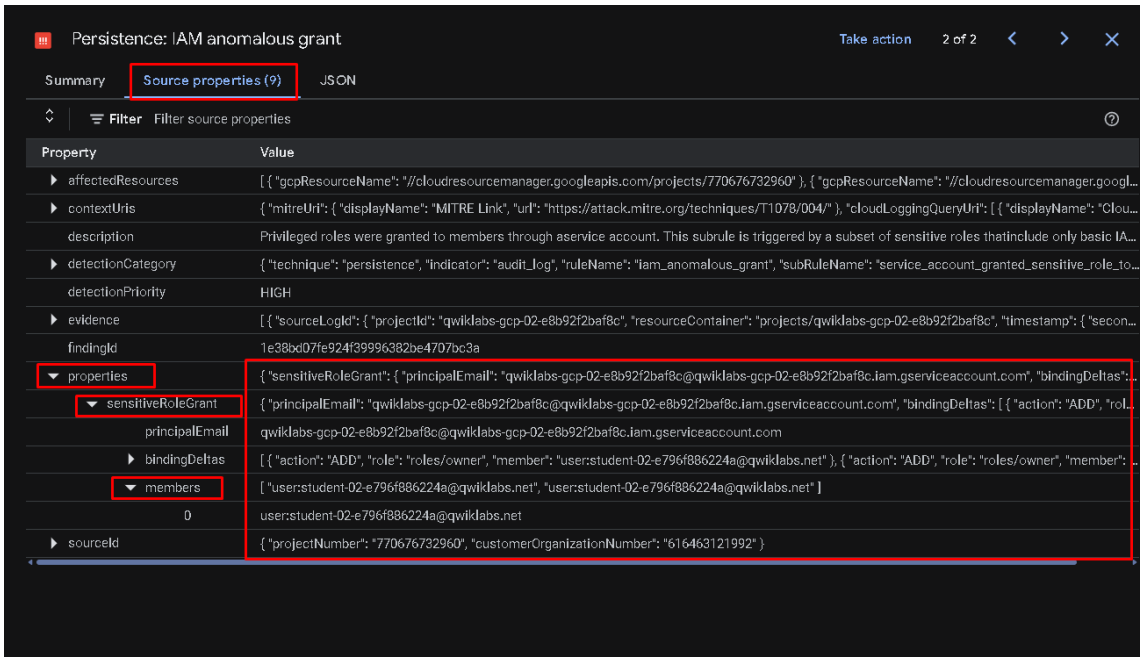

when a specific criteria is met. Learn more about IAM conditions
Search Service, role or permission
Quick access
Currently used
Custom
Basic
Job function based
By product or service
Roles
Browser
Editor
Owner
Viewer
Manage Roles
Owner
Full access to most Google Cloud resources. See the list of included permissions.
principal can
Full access to most Google Cloud resources. See the list of included permissions.
+ Add another role
Help me choose roles

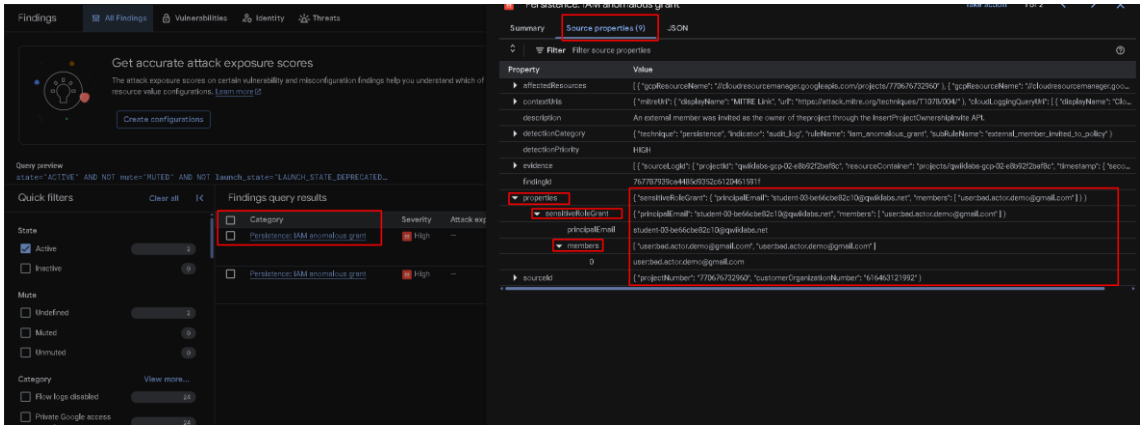


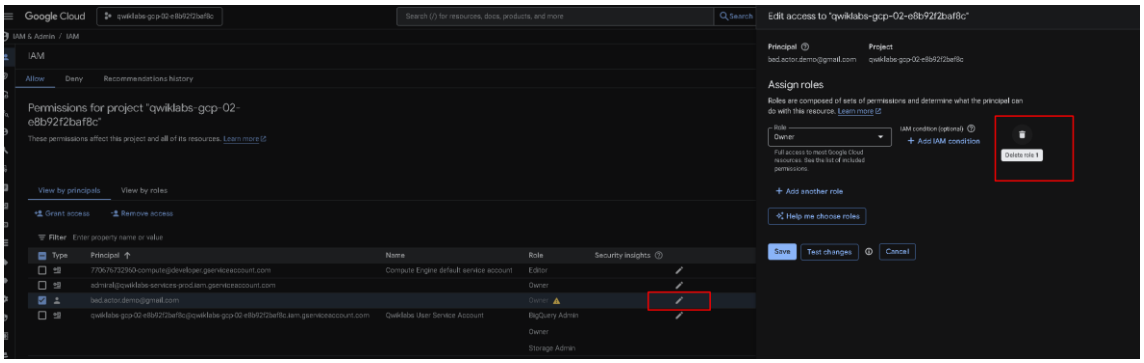
Tarefa 2: Acessar as descobertas do Event Threat Detection


Google Cloud
Cloud Hub
Cloud overview
Solutions
Recently visited
Favorite products
Favorite products appear here
Products
Billing
IAM & Admin
Marketplace
APIs & Services
Vertex AI
Compute Engine
Kubernetes Engine
Cloud Storage
Security
BigQuery
Security Command Center
Overview
Graph Search
Issues
Findings
Assets
Compliance
Posture Management
Sources
Detections and Controls
Google SecOps
reCAPTCHA
Model Armor
Web Security Scanner
Cyber Insurance Hub
Binary Authorization
Advisory Notifications
Access Approval
Managed Microsoft AD
Data Protection
Sensitive Data Protection
Data Loss Prevention
Data Security & Compliance
Learn more


Persistence: IAM anomalous grant
Take action
2 of 2
Summary
Source properties (9)
JSON
What was detected
Description
Privileged roles were granted to members through aservice account. This subrule is triggered by a subset of sensitive roles thatinclude only basic IAM roles and certain data storage roles.
State
Active
state
Severity
High
severity
Event time
February 25, 2026, 9:01:50 PM GMT-3
event_time
Create time
February 25, 2026, 9:01:50 PM GMT-3
create_time
Principal email
qwiklabs-gcp-02-e8b92f2baf8c@qwiklabs-gcp-02-e8b92f2baf8c.iam.gserviceaccount.com
access.principal_email
Caller IP
gce-internal-ip
access.caller_ip
User agent
google-api-go-client/0.5 Terraform/1.0.1 (+https://www.terraform.io) Terraform-Plugin-SDK/2.38.1 terraform-provider-google/7.21.0.gzip(gfe)
access.user_agent
Service name
cloudresourcemanager.googleapis.com
access.service_name
Method name
SetIamPolicy
access.method_name
Principal subject
serviceAccount:qwiklabs-gcp-02-e8b92f2baf8c@qwiklabs-gcp-02-e8b92f2baf8c.iam.gserviceaccount.com
access.principal_subject
Service account key name
//iam.googleapis.com/projects/qwiklabs-gcp-02-e8b92f2baf8c/serviceAccounts/qwiklabs-gcp-02-e8b92f2baf8c@qwiklabs-gcp-02-e8b92f2baf8c.iam.gserviceaccount.com/keys/2677ee48c53147bbdae68b2ece7b3704e73d40ce
access.service_account_key_name
Offending access grants
Review 1 offending access grant
iam_binding
Affected resource
Resource display name
qwiklabs-gcp-02-e8b92f2baf8c
resource.display_name


Persistence: IAM anomalous grant
Take action
2 of 2
Summary
Source properties (9)
JSON
Filter
Filter source properties
Property
Value
affectedResources
[{ "gcpResourceName": "//cloudresourcemanager.googleapis.com/projects/770676732960" }, { "gcpResourceName": "//cloudresourcemanager.googl...
contextUris
{ "mitreUri": { "displayName": "MITRE Link", "url": "https://attack.mitre.org/techniques/T1078/004/" }, "cloudLoggingQueryUri": [{ "displayName": "Clou...
description
Privileged roles were granted to members through aservice account. This subrule is triggered by a subset of sensitive roles thatinclude only basic IA...
detectionCategory
{ "technique": "persistence", "indicator": "audit_log", "ruleName": "iam_anomalous_grant", "subRuleName": "service_account_granted_sensitive_role_to...
detectionPriority
HIGH
evidence
[{ "sourceLogId": { "projectId": "qwiklabs-gcp-02-e8b92f2baf8c", "resourceContainer": "projects/qwiklabs-gcp-02-e8b92f2baf8c", "timestamp": { "secon...
findingId
1e38bd07fe924f39996382be4707bc3a
properties
{ "sensitiveRoleGrant": { "principalEmail": "qwiklabs-gcp-02-e8b92f2baf8c@qwiklabs-gcp-02-e8b92f2baf8c.iam.gserviceaccount.com", "bindingDeltas":...
sensitiveRoleGrant
{ "principalEmail": "qwiklabs-gcp-02-e8b92f2baf8c@qwiklabs-gcp-02-e8b92f2baf8c.iam.gserviceaccount.com", "bindingDeltas": [{ "action": "ADD", "rol...
principalEmail
qwiklabs-gcp-02-e8b92f2baf8c@qwiklabs-gcp-02-e8b92f2baf8c.iam.gserviceaccount.com
bindingDeltas
[{ "action": "ADD", "role": "roles/owner", "member": "user:student-02-e796f886224a@qwiklabs.net" }, { "action": "ADD", "role": "roles/owner", "member": ...
members
["user:student-02-e796f886224a@qwiklabs.net", "user:student-02-e796f886224a@qwiklabs.net"]
0
user:student-02-e796f886224a@qwiklabs.net
sourceId
{ "projectNumber": "770676732960", "customerOrganizationNumber": "616463121992" }


Findings
All Findings
Vulnerabilities
Identity
Threats
Get accurate attack exposure scores
Create configurations
Quick filters
Findings query results
Category
Severity
Persistence: IAM anomalous grant
Summary
Source properties (9)
JSON
Property
Value


Google Cloud
IAM & Admin / IAM
IAM
Allow
Deny
Recommendations history
Permissions for project "qwiklabs-gcp-02-e8b92f2baf8c"
View by principals
View by roles
Grant access
Remove access
Type
Principal
Name
Role
Security insights
Edit access to "qwiklabs-gcp-02-e8b92f2baf8c"
Principal
Project
Assign roles
Owner
Add IAM condition
Delete role
Add another role
Help me choose roles
Save
Test changes
Cancel